Sofacy Fysbis Backdoor Investigation - Student Briefing

1. Malware Overview

- Family / type: Sofacy (Fysbis)
- Aliases: Not specified in this scenario
- Behaviour class: Backdoor
- What it does:
- Implements plug-in and controller modules as distinct classes.
- Can install itself with or without root privileges.
- Uses shell commands to establish persistence.
- Communicates with C2 servers.
- Exfiltrates data.
- Associated MITRE ATT&CK techniques:
- Persistence: T1547.001 (Registry Run Keys / Startup Folder)
- Privilege Escalation: T1068 (Exploitation for Privilege Escalation)
- Defense Evasion: T1036 (Masquerading)
- Command and Control: T1071 (Application Layer Protocol)
- Exfiltration: T1041 (Exfiltration Over C2 Channel)
- Associated CVEs: Not specified in this scenario

2. Exercise Objective

- Learning goal: Investigate a compromised host infected with the Sofacy Fysbis backdoor, identify malicious activities, and contain the threat.
- Difficulty level: Intermediate
- Cybersecurity approach: Defence-oriented
- NICE work role: Incident Response
- Successful trainee: Will have demonstrated the ability to investigate a compromised host, identify suspicious services and timers, and determine network ports associated with unauthorized communication.

3. Sandbox Topology & Malware Emulation

- Hosts:
- c2-server: IP 192.168.40.5
- target: IP 192.168.50.5
- next-target: IP 192.168.50.6
- Networks:
- server-switch: CIDR 192.168.40.0/24
- target-switch: CIDR 192.168.50.0/24
- Network layout:

```
  server-switch (192.168.40.0/24)
    |
    |-- c2-server (192.168.40.5)
  target-switch (192.168.50.0/24)
    |
    |-- target (192.168.50.5)
    |
    |-- next-target (192.168.50.6)
```

- Malware emulation:
- Service: systemkernelservicedefender.service (emulates the backdoor service)
- Port: 80 (emulates the C2 communication port)
- Timer: lab-checkin.timer (emulates the periodic execution of the suspicious service)

- Files:
- ksysdefd (emulates the payload)
- fd8b2ea9a2e8a67e4cb3904b49c789d57ed9b1ce5bebfe54fe3d98214d6a0f61 (emulates the payload hash)
- Host: target (192.168.50.5)

4. Student Tasks

- ACCESS step:
- Credentials: Username cyrano, Password cyrano
- Start passkey: start
- TRAINING_LEVEL 1:
- Task: Investigate the running services and identify the service responsible for the suspicious activity.
- TYPE of artifact/flag expected: Service name
- TRAINING_LEVEL 2:
- Task: Investigate the service and determine the network port associated with this communication.
- TYPE of artifact/flag expected: Port number
- TRAINING_LEVEL 3:
- Task: Investigate the host and identify the service responsible for periodic execution of the suspicious service.
- TYPE of artifact/flag expected: Timer name

5. Solution Walkthrough & Flags

- TRAINING_LEVEL 1:
- Methodology:
  1. Connect to the target host using SSH:
     ```
     ssh cyrano@192.168.50.5
     ```
  2. List all services to identify the suspicious one:
     ```
     systemctl list-units --type=service --all
     ```
  3. Look for any unfamiliar or suspicious service names. Pay attention to services with unusual descriptions or those that are not part of standard system services.
  4. The suspicious service is likely to be named systemkernelservicedefender.service.
- Flag: systemkernelservicedefender.service
- TRAINING_LEVEL 2:
- Methodology:
  1. Connect to the target host using SSH:
     ```
     ssh cyrano@192.168.50.5
     ```
  2. Check the status of the suspicious service identified in the previous task:
     ```
     systemctl status systemkernelservicedefender.service
     ```
  3. Look for the port number in the service configuration. The port number is likely specified in the ExecStart line.
  4. The port number used by the suspicious service is 80.
- Flag: 80
- TRAINING_LEVEL 3:
- Methodology:
  1. Connect to the target host using SSH:
     ```
     ssh cyrano@192.168.50.5
     ```
  2. List all timers to identify the one responsible for periodic execution of the suspicious service:
     ```
     systemctl list-timers --all
     ```
  3. Look for any unfamiliar or suspicious timer names. Pay attention to timers with unusual descriptions or those that are not part of standard system timers.
  4. The suspicious timer is likely to be named lab-checkin.timer.
- Flag: lab-checkin.timer

6. Knowledge Gained

- Skills:
- Investigating running services using systemctl
- Identifying suspicious services and timers
- Determining network ports associated with unauthorized communication
- Tools:
- systemctl
- ssh
- Concepts:
- Incident Response
- Malware Analysis
- System Investigation
- NICE role: Incident Response
- MITRE techniques:
- Persistence: T1547.001
- Privilege Escalation: T1068
- Defense Evasion: T1036
- Command and Control: T1071
- Exfiltration: T1041